Group 5:
Zero trust models and how limiting access can strengthen cybersecurity

Phạm Thế Đăng BH01842
Nguyễn Công Duy BH01530
Nguyễn Bá Quang Huy BH1789
Nguyễn Kim Hoàng BH01790

Table of Contents

1 Introduction to Cybersecurity and Security Challenges

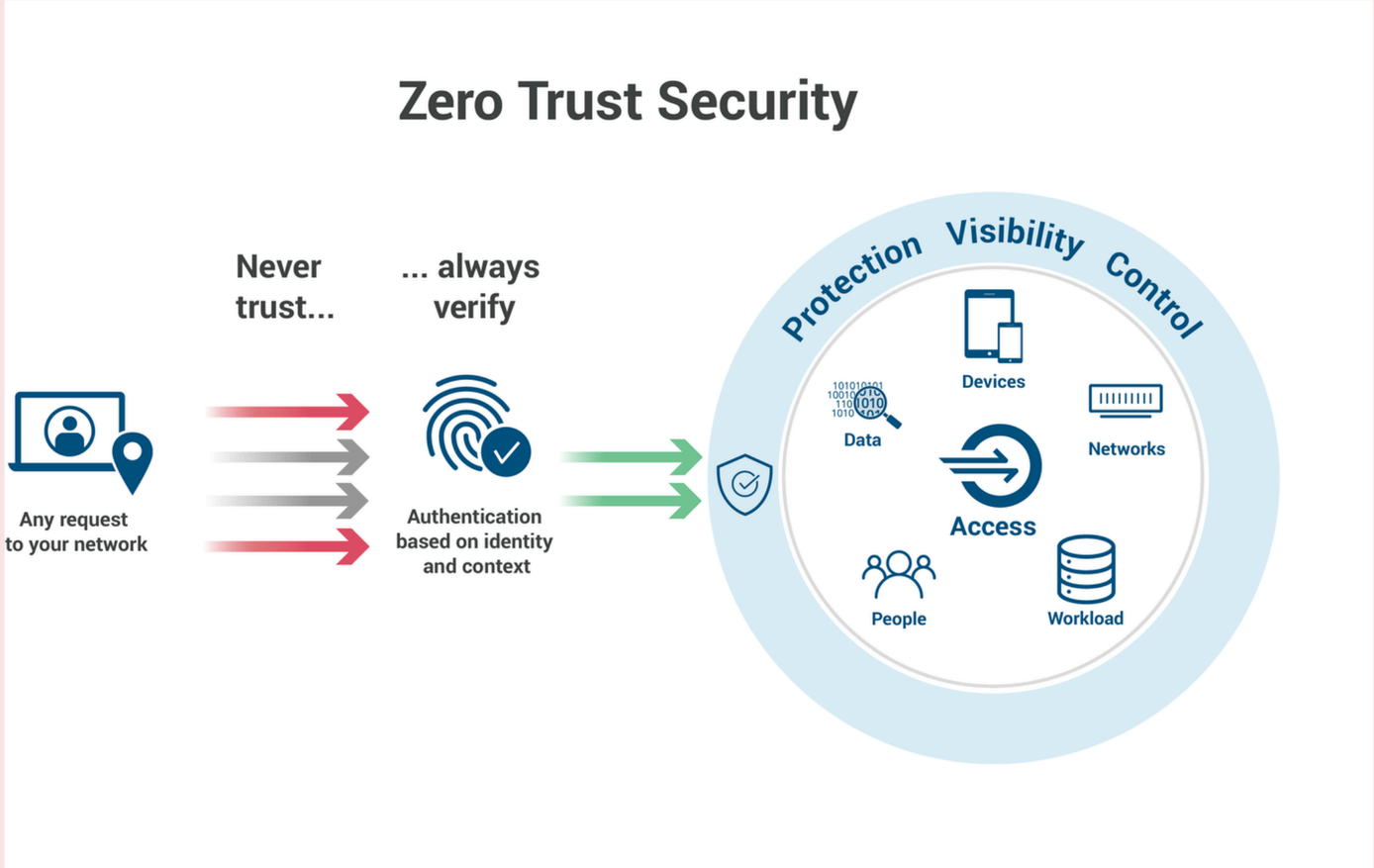
2 Overview of the Zero Trust Model

3 Core Principles and Architecture of Zero Trust

4 Access Control and Limiting Access in Zero Trust

5 Benefits and Challenges of Implementing Zero Trust

6 Conclusion and Future Trends in Cybersecurity



1. Introduction to Cybersecurity and Security Challenges

Introduction to Cybersecurity and Security Challenges

- Cybersecurity is the practice of protecting computer systems, networks, and data from cyberattacks, unauthorized access, and damage.
- It focuses on three main principles known as the CIA Triad:
- Confidentiality – Protecting sensitive data
- Integrity – Ensuring data accuracy and reliability
- Availability – Making systems and information accessible when needed
- Cybersecurity is essential for protecting digital information and maintaining secure online operations.

Importance of Cybersecurity

- Cybersecurity is important for modern organizations because they rely heavily on digital systems and online services.
- Key reasons include:
- Protecting sensitive business and customer data
- Preventing financial losses from cyberattacks
- Ensuring business continuity
- Building trust with users and customers
- Strong cybersecurity strategies help organizations operate safely in the digital environment.

Cybersecurity Challenges

Organizations face many cybersecurity challenges today, such as:
Phishing attacks that steal personal information
Malware and ransomware that damage systems or lock data
Insider threats from employees or internal users
Weak access control leading to unauthorized access
These challenges show the need for modern security approaches like Zero Trust.

2. Overview of the Zero Trust Model

2.1 What is Zero Trust?

- Zero Trust is a modern cybersecurity model designed to protect an organization's systems and data.
- Unlike traditional security models, Zero Trust doesn't default to trusting any user, device, or application, whether they are inside or outside the internal network.
- This model requires every access request to be verified before granting permission.

Core principle:
“Never Trust, Always Verify”
(Never trust by default – always verify)

2.2 Why was the Zero Trust model created?
In traditional security systems:

- Internal networks are generally considered secure.
- Users within the network are typically trusted by default.

However, in the modern technological environment:

- Employees work remotely.
- Personal devices are used.

System access is via the Internet.
This blurs the lines between internal and external networks, creating numerous security vulnerabilities.

2. Overview of the Zero Trust Model

2.3 The core idea of Zero Trust

Zero Trust requires the system to verify every access request based on:

- Identity Authentication
  Verifying users through passwords, MFA, or other security methods.
- Access Authorization
  Only allowing access to resources appropriate to the user's role.
- Continuous Monitoring
  Monitoring user activity to detect unusual behavior.

2..4 Key Principles of Zero Trust

1. Least Privilege Access
   - Users are only granted the minimum necessary access privileges.
   - Reduces the risk of abuse of privileges or unauthorized access.
2. Continuous Verification
   - The system verifies users not just once upon login but throughout the entire access process.
3. Micro-Segmentation
   - The system is divided into many small parts to limit the scope of an attack if a security incident occurs.

2. Overview of the Zero Trust Model

2.5 Benefits of the Zero Trust Model:

- Enhanced system access control
- Reduced risk of cyberattacks and data leaks
- Faster detection of unusual access activity
- Better protection of critical business resources and data

3. Core Principles and Architecture of Zero Trust

The Zero Trust model is built on several key principles to ensure that all access to the system is tightly controlled and secure.

1. Never Trust, Always Verify

This is the most important principle of Zero Trust.

- The system does not trust any user or device by default.
- Every access request must be verified before authorization.

Verification may include:

- password
- multi-factor authentication (MFA)
- device check.

3.Core Principles and Architecture of Zero Trust

2. Least Privilege Access
Users are only granted the minimum necessary access to perform their work.
This reduces the risk of:

- unauthorized access
- abuse of system privileges
- leaking of critical data.

Example:

- Employees can only access data related to their work.

3. Continuous Monitoring and Verification

- The system does not verify users only once upon login.
- User activity is continuously monitored throughout the access period.

If unusual behavior is detected, the system can:

- request re-authentication
- restrict access
- block access.

3.Core Principles and Architecture of Zero Trust

4. Micro-Segmentation

- The network system is divided into many small segments.
- This helps reduce the scope of an attack if one part of the system is compromised.
- It will be difficult for an attacker to move to other parts of the system.

5. Identity-Centric Security

- Zero Trust focuses on the identity of users and devices.

Access decisions are based on:

- user identity
- device state
- access location
- access behavior.

4. Access Control and Limiting Access in Zero Trust

4.1. Main Access Control Mechanisms:

- To implement "Never Trust, Always Verify," Zero Trust combines several modern access control models:

- RBAC (Role-Based Access Control): Grants permissions based on job roles. For example: Only people in the "Accounting" group have access to the financial software.

- ABAC (Attribute-Based Access Control): This is a more advanced level, granting permissions based on dynamic attributes such as:

  - User: Job title, department.
  - Device: Is antivirus software installed? Is it a company device?
  - Environment: What time was access? From which IP address?

- CBAC (Context-Aware Access Control): Controls access based on context. If an administrator logs in from Hanoi at 8 AM and then logs in from London 5 minutes later, the system will automatically block access due to the unusual context of the behavior.

4.2. Access Restriction Strategies

Access restriction in Zero Trust aims to minimize the "blast radius" when an incident occurs.

2.1. Principle of Least Privilege (PoLP)

- This is the heart of access restriction. Users are only granted sufficient permissions to complete a specific task within a specific timeframe.
- Example: A system maintenance engineer is only granted "Fix errors" permission for 2 working hours, after which this permission is automatically revoked.

2.2. Micro-segmentation

- Instead of dividing the network into large VLANs, Zero Trust divides the network into extremely small segments surrounding each application or database.
- How it works: Set up a virtual firewall for each workload. If the web server is attacked, the attacker cannot access the database server because there are no permission rules between these two segments.

2.3. Dynamic Access Control

- Access is not granted permanently. The system continuously reassesses the trust score of the session.
- Just-In-Time (JIT): Permissions are only granted when needed.
- Just-Enough-Access (JEA): Only necessary commands/tasks are granted.

4.3. Access Restriction Enforcement Process

This process takes place at the Policy Enforcement Point (PEP) under the control of security policies:

- Default Deny: All connections are blocked until clearly verified.
- Multi-Factor Authentication (MFA): Requires at least two proofs (password + OTP/Biometrics) before granting access.
- Device Authentication: Checks the security status of the device requesting access.
- Policy-Based Authorization: The Policy Engine matches attributes (ABAC) to open a temporary data stream.
- Immediate Revocation: If the device is infected with malware while accessing, the PEP will immediately disconnect to protect resources.

4.4. The Importance of Access Restrictions

- Strict access restrictions help businesses:
  - Defend against lateral movement attacks: Attackers cannot penetrate deep into the data center from a compromised personal computer.
  - Minimize internal risks: Employees cannot view data outside their work scope.
  - Comply with international standards: Meet the stringent requirements of GDPR, ISO 27001, or NIST.

5. Benefits and Challenges of Implementing Zero Trust

5.1. Benefits of Implementing Zero Trust

-The Zero Trust model offers superior protection by eliminating default trust.

- Preventing Lateral Movement Attacks: By using micro-segmentation, Zero Trust isolates each resource. If an account or device is compromised, the attacker is trapped in a small segment and unable to penetrate deeper into other sensitive systems.
- Protecting Data in Remote Work Environments: Zero Trust doesn't care where the user is (coffee shop, home, or office). Every connection is authenticated equally, eliminating reliance on traditional VPNs that are easily exploited.
- Visibility: Because every access request must go through a Point of Control (PEP), administrators can accurately monitor Who is doing What, on Which Device, and When. This creates an extremely detailed system log for incident investigation.
- Minimizing Insider Threats: The Principle of Least Access (PoLP) ensures employees only see what they need for their work, minimizing data leaks, whether accidental or intentional.

5.2. Challenges in Implementing Zero Trust

- Despite its significant benefits, transitioning to Zero Trust is not an overnight process.

- Complexity in configuration management: Setting up granular access control policies for each user and application (ABAC/RBAC) requires a deep understanding of the organization's workflow. Misconfiguration can lead to the wrongful blocking of legitimate access, causing business disruption.
- Problems with legacy systems: Many legacy applications do not support modern authentication protocols (such as SAML, OAuth 2.0) or cannot operate in a micro-segment environment. Upgrading or replacing these systems is very costly.
- Impact on user experience (UX): If not optimized, the constant multi-factor authentication (MFA) requests or latency from access control points can frustrate employees and reduce productivity.
- High initial investment costs: Implementing Zero Trust requires investment in new technologies such as Identity Management (IAM), behavioral monitoring systems, and a highly qualified team of experts to operate it.

6. Conclusion and Future Trends in Cybersecurity

6.1. Conclusion

- The Inevitable Shift: Zero Trust is no longer an optional strategy but a mandatory standard in the digital transformation era. By eliminating "implicit trust," organizations can reduce data breach impact by up to 73%.
- Identity-Centric Focus: The security paradigm has shifted from perimeter-based protection to a robust focus on user and device identity.
- Holistic Resilience: Success in Zero Trust relies not only on technology but on the integration of Continuous Verification and an "Assume Breach" mindset.

6.2. Future Trends

1. AI-Driven Zero Trust:
   - Leveraging Machine Learning (ML) for real-time user behavior analytics.
   - Implementing automated, risk-based access control adjustments without human intervention.
2. Quantum-Resistant Zero Trust:
   - Integrating Post-Quantum Cryptography (PQC) into the architecture to safeguard sensitive data against emerging quantum computing threats.
3. Cloud & Edge Convergence:
   - Deep integration of Zero Trust with SASE (Secure Access Service Edge) to ensure consistent protection for remote users and IoT devices.
4. Behavioral Biometrics:
   - Moving beyond static passwords and MFA by implementing authentication based on behavioral patterns, such as mouse movement, typing cadence, and application usage habits.